

Asset Maintenance Tool – Product Requirements Document (PRD)

****Version:**** 1.0.0

****Status:**** Draft – pending client approval

****Last updated:**** 2026-08-15

****Owner:**** Founding Product Architect

****Stable requirement IDs:**** FR-*, NFR-*, RBAC-*, ACE-*

1. Problem Statement

Organizations struggle to maintain accurate, up-to-date inventories of their physical assets (laptops, desktops, mobile devices, peripherals, furniture, etc.). Existing processes rely on periodic manual audits, spreadsheets, or disparate tools that lack real-time visibility, automated custody tracking, and integrated lifecycle management. This leads to:

- ****Lost or underutilized assets**** – devices go missing or sit idle, driving unnecessary procurement costs.
- ****Compliance risk**** – inability to prove asset location, software licensing, or disposal records during audits.
- ****Inefficient maintenance**** – reactive break-fix instead of planned preventive work, increasing downtime.
- ****Poor custodian accountability**** – unclear who is responsible for an asset at any given time.
- ****Fragmented data**** – asset information spread across ITSM, finance, and facilities systems without a single source of truth.

The reference application (AssetTiger) demonstrates a web-based asset management workflow but lacks:

- A trusted endpoint agent for continuous hardware/software inventory on employee laptops.
- Modern, tenant-scoped security with deny-by-default RBAC and automated authorization testing.
- A responsive, mobile-first UI with barcode/QR scanning and offline-capable audit.
- Integrated AI-assisted data cleanup and predictive maintenance suggestions.
- A visual label designer for Zebra-compatible tags.
- Explicit, tested asset-tag uniqueness policies with migration and duplicate handling.

2. Vision & Success Metrics

****Vision:**** Provide growing organizations with a secure, real-time, multi-tenant asset maintenance SaaS that continuously knows what assets they own, where they are, who is responsible, and how they are used—enabling proactive lifecycle decisions, reducing waste, and ensuring audit readiness.

****Success Metrics (to be measured within 6 months of MVP launch):****

| Metric | Target | Measurement Method |

|-----|-----|-----|

| Asset inventory accuracy | $\geq 98\%$ of assets reconciled within 24 h of change | Periodic audit vs. SaaS record |

| Mean time to detect missing laptop | ≤ 4 hours | Agent offline detection + sync |

| Percentage of assets with up-to-date software inventory | $\geq 95\%$ | Agent-reported installed software list |

| Mean time to resolve custody transfer request | ≤ 2 business days | Ticket system SLA |

| Reduction in manual audit effort | $\geq 60\%$ vs. baseline | Hours spent on periodic audits |

| Critical security findings (pen-test) | Zero high-severity | Third-party assessment |

| User satisfaction (NPS) | ≥ 40 | Quarterly survey |

| MVP adoption (active orgs) | ≥ 5 paying tenants | Billing system |

3. Target Customers & Personas

| Customer Segment | Description | Primary Personas |

|-----|-----|-----|

| ****Growing SMBs (50-500 employees)**** | Companies scaling beyond spreadsheets, needing centralized asset tracking but without enterprise-level IT budgets. | IT Asset Manager, Office Administrator, Finance Controller |

| ****Distributed enterprises (multiple sites)**** | Organizations with several offices, warehouses, or remote workers needing site-level visibility. | Facilities Manager, Regional IT Lead, HR Asset Coordinator |

| ****Managed Service Providers (MSPs)**** | Third-party IT firms managing assets for multiple client tenants. | Service Delivery Manager, Technical Account Manager |

****Personas (detailed):****

1. ****IT Asset Manager (IAM)**** – Responsible for the complete asset lifecycle, runs regular audits, ensures compliance, and generates reports for leadership. Needs bulk import/export, role-based views, automated alerts, and audit-ready history.

2. ****Employee / End User (EU)**** – Receives assets (laptop, phone, monitor) and is accountable for its care and return. Needs self-service portal to request assets, report issues, view assigned items, and initiate check-in/out.
3. ****Field Technician (FT)**** – Performs maintenance, repair, and upgrade work on assets. Needs work order details, barcode scanning for quick identification, parts usage logging, and offline capability.
4. ****Finance & Procurement Lead (FPL)**** – Oversees asset budgeting, depreciation, and vendor contracts. Needs financial reports, warranty/expiration tracking, and cost center allocation.
5. ****Administrator / Superadmin (SA)**** – Configures tenants, roles, integrations, branding, and system-wide settings. Needs full control over security policies, data retention, and audit logs.

4. Jobs to be Done (JTBD)

| Situation | Motivation | Expected Outcome |

|-----|-----|-----|

| When I onboard a new employee | I want to assign the correct laptop, monitor, and accessories quickly and record the custodian | Asset is checked out to the user, custodian field updated, and an audit event is created |

| When I notice a laptop running slow | I want to check its hardware specs, installed software, and recent usage to decide if it needs upgrade or replacement | I can view a timeline of utilization, see installed apps, and open a maintenance ticket if needed |

| When I am preparing for a quarterly audit | I need to prove that every asset is accounted for, licensed, and in the correct location | I can export a filtered asset list with location, custodian, and status, and the system shows zero discrepancies after reconciliation |

| When an employee leaves the company | I must retrieve all assigned assets, wipe data, and update the asset status to “available” or “disposed” | The system guides the return checklist, marks the asset as checked in, and triggers a retirement workflow if applicable |

| When I need to order new monitors | I want to see which models are underutilized or nearing end of life to avoid unnecessary spend | I can filter by model, age, and usage, and see a recommendation to redeploy existing units first |

| When a laptop is reported stolen | I must locate it quickly, lock it down, and initiate an insurance claim | The last known location, IP address, and recent usage are visible; I can flag the asset as lost and start a workflow |

5. Product Principles & Differentiation Strategy

****Principles****

- ****Tenant first isolation:**** Every API, query, and storage operation enforces tenant scope; cross-tenant access is blocked by default.

- **Security by design:** Deny by default RBAC, encrypted secrets, malware scanned file uploads, immutable audit logs, and automated authorization testing.
- **Evidence driven:** Every implemented behavior is traceable to an OBSERVED, INFERRED, or PROPOSED evidence item; unknowns become explicit product decisions requiring client approval.
- **Continuous inventory:** Lightweight agents on endpoints provide real time hardware/software data, reducing reliance on periodic scans.
- **Mobile first, offline capable:** Core audit workflows work on smartphones/tablets with intermittent connectivity.
- **Extensible & integrable:** Configurable webhooks, import/export templates, and a public API enable connection to ITSM, CMDB, and HR systems.
- **Sustainable by design:** Features that support asset reuse, lifespan tracking, and e-waste reporting.

Differentiation vs. Reference Application

Area	Reference (AssetTiger)	Our Product (Asset Maintenance Tool)
Endpoint data	Manual or periodic scans only	Optional lightweight agent delivering continuous installed software, hardware health, usage, and online/offline status
Security model	Role based UI controls, incomplete matrix	Deny by default service layer RBAC, explicit per action permissions, automated role based tests, MFA ready, SSO ready
Asset tag uniqueness	UI level duplicate warning only (persistence unknown)	Tenant scoped uniqueness enforced at API and DB layers, with migration, duplicate handling, and clear error contract
UI/UX	Server rendered forms, jQuery/Bootstrap era	Responsive, component based UI with design system tokens, mobile barcode scanning, offline PWA support
Label printing	Static templates only	Visual label designer for Zebra compatible templates, live preview, and direct print job submission
Data quality	Length limits observed only	Normalization, validation patterns, enumerations, ranges, required/nullability defined per field
Lifecycle events	Basic check in/out, lease, dispose	Full custody transfer, reservation, maintenance, return, retirement, disposal with audit trail and approval workflow
Reporting	Pre defined reports	Drag and drop report builder with charting, filtering, scheduled delivery, and webhook triggers
AI assistance	None	AI suggested asset tag cleanup, predictive maintenance hints, and reconciliation suggestions during audit
Integration	Limited CSV import/export	Configurable inbound/outbound webhooks, API key management, and webhook signature verification
Deployment & ops	Unknown (likely monolithic VM)	Modern SaaS: managed relational DB, object storage, background workers, observability (logs, metrics, tracing), automated backups, and tested rollback plan

6. Module Inventory

The product is organized into the following high-level modules (each may be broken into sub-features):

1. ****Identity, Tenants & RBAC**** – user management, tenant provisioning, roles, permissions, MFA, SSO, API keys.
2. ****Sites, Locations, Categories & Departments**** – hierarchical taxonomy for organizing assets.
3. ****People, Users & Groups**** – employee directory, custody assignment, group-based permissions.
4. ****Asset Registry**** – core asset record, unique tag, serial number, status, lifecycle events, attachments.
5. ****Custom Fields & Configurable Forms**** – tenant-defined fields, form layouts, validation rules, and dynamic sections.
6. ****Check-out / Check-in / Custody**** – lending assets, return process, overdue alerts, and transfer workflows.
7. ****Lease, Reserve, Maintenance & Disposal**** – scheduling, work-order management, parts usage, warranty tracking, and retirement.
8. ****Inventory & Audit Sessions**** – barcode/QR scanning sessions, discrepancy handling, reconciliation, and audit history.
9. ****Contracts, Vendors & Warranties**** – agreement tracking, renewal alerts, and service-level tracking.
10. ****Documents, Images & Attachments**** – secure file storage, malware scanning, versioning, and access controls.
11. ****Configurable Forms, Tables & Events**** – user-defined data structures and workflow triggers.
12. ****Dashboards, Reports & Alerts**** – pre-built and ad-hoc visualisations, scheduled delivery, and threshold-based notifications.
13. ****Imports, Exports & Bulk Operations**** – validated CSV/JSON processing, idempotency, and partial-failure policy.
14. ****QR / Barcodes & Mobile Scanning**** – generation, scanning, deep links, and offline caching.
15. ****Zebra Label Design & Printing**** – template editor, print-job submission, and printer-profile management.
16. ****Subscription, Billing & Entitlements**** – plan management, usage metering, proration, and dunning.
17. ****New Feature Incubator**** – proposed differentiators (AI data cleanup, offline audit, predictive maintenance, etc.) awaiting approval.

Each module will have its own feature specification (see `docs/features/`) with stable functional-requirement IDs.

7. Functional Requirements

****Format:**** `FR--` where `` is a short code (e.g., ASSET, RBAC, AUDIT).

All requirements are ****testable**** and traceable to acceptance criteria.

| ID | Description | Priority (Must/Should/Could) | Linked Evidence (ID) |

|---|-----|-----|-----|

| FR-TENANT-001 | The system shall support multiple isolated tenants; each tenant has its own database schema (shared physical with tenant column) or separate schema, and no data leaks across tenants. | Must | EV-ARCH-01 (OBSERVED: multi-tenant implied by SaaS) |

| FR-RBAC-001 | Every API endpoint shall enforce deny-by-default authorization: a request is rejected unless the caller's role policy explicitly grants the action on the target resource. | Must | EV-SEC-MODEL-01 (PROPOSED: deny-by-default RBAC) |

| FR-RBAC-002 | The system shall provide pre-defined roles: Super-admin, Tenant Admin, IT Asset Manager, Field Technician, Employee (self-service only), Auditor, and Read-Only. Additional custom roles can be created by combining granular permissions. | Should | EV-SEC-MODEL-01 (PROPOSED) |

| FR-ASSET-001 | Each asset record shall have a ****tenant-scoped unique Asset Tag**** (string) that serves as the primary user-friendly identifier. The system shall prevent creation of two assets with the same normalized tag within the same tenant. | Must | EV-RULES-JSON-001 (OBSERVED: duplicate-tag validation alert, CONFLICTING about persistence) – proposed decision to enforce uniqueness. |

| FR-ASSET-002 | Asset Tag shall be normalized per rule: trim whitespace, convert to uppercase, and allow only alphanumeric characters plus hyphen and underscore. | Must | Derived from FR-ASSET-001 and observed max length 50 (BR-0003, BR-0060, BR-0103) |

| FR-ASSET-003 | Asset record shall capture: Serial No (optional), Make/Model, Category, Site, Location, Department, Custodian (user or group), Status (In Stock, Assigned, In Repair, On Loan, Retired, Disposed), Purchase Date, Cost, Warranty Expiry, and associated Contract. | Must | EV-LDM-001 (INFERRED: fields observed across forms) |

| FR-ASSET-004 | The system shall store an immutable audit event for any change to the asset's core fields (tag, serial, status, custodian, location, cost, warranty) – including who made the change, timestamp, and diff. | Must | EV-ARCH-01 (PROPOSED: immutable audit events); EV-ACCEPT-004 (PROPOSED) |

| FR-ASSET-005 | Users with proper permission may check-out an asset to a custodian (user or group), which sets Status = Assigned, logs the custodian and expected return date, and creates an audit event. | Must | EV-ROUTES-001 (OBSERVED: checkout request/data and checkout pages) |

| FR-ASSET-006 | Upon check-in, the system shall verify the asset matches the custodian record, clear the custodian field, set Status based on condition (e.g., In Stock, In Repair), and create an audit event. | Must | EV-ROUTES-001 (OBSERVED: checkin request/data and checkin pages) |

| FR-ASSET-007 | The system shall support reservation of an asset for a future date/time, preventing check-out to others during the window, and notifying the requester when the asset becomes available. | Should | Inferred from lifecycle backlog (IB-03) |

| FR-ASSET-008 | Maintenance work orders shall be creatable against an asset, track labor hours, parts used, downtime, and set Status = In Repair during work; on completion, Status returns to prior state (or Retired/Disposed if end-of-life). | Should | Inferred from lifecycle backlog (IB-03) |

| FR-ASSET-009 | When an asset is marked Disposed or Retired, the system shall require disposal method (e.g., recycled, donated, destroyed), final cost, and generate a final audit event before blocking further changes. | Must | Inferred from lifecycle backlog (IB■03) |

| FR-AUDIT-001 | Authorized users may start an **audit session** for a given site, location, department, or asset list, which opens a barcode/QR scanning interface (web or mobile) to scan asset tags and record status (Found, Missing, Mismatched, Damaged). | Must | EV■ROUTES■001 (OBSERVED: audit■related routes) |

| FR-AUDIT-002 | During an audit, if a scanned tag is not found in the expected location, the system shall flag a mismatch and allow the user to mark the asset as Missing, update its last known location, and optionally add notes. | Must | Inferred from audit backlog (IB■05) |

| FR-AUDIT-003 | After completing an audit session, the user may **reconcile** discrepancies: the system suggests likely matches (based on last■seen location, similar models, or recent custody transfers) and the user can confirm, update records, or mark as truly missing. | Should | Proposed AI■assisted reconciliation (incubator) |

| FR-AUDIT-004 | Audit session data shall be stored with tenant■scoped immutable audit logs, including scan timestamps, user ID, and device/fingerprint (if available). | Must | EV■ACCEPT■012 (PROPOSED: observable audit) |

| FR-AGENT-001 | An optional, lightweight endpoint agent shall be available for Windows, macOS, and Linux laptops that collects: installed software (name, version, publisher), usage statistics (focus time, launch counts), hardware specs (CPU, RAM, storage, GPU), OS version & patch level, network status (online/offline, VPN), security status (AV/FW status, disk encryption), and last communication timestamp. | Should | Client■provided idea (Task 1) |

| FR-AGENT-002 | The agent shall transmit data via mutually■authenticated HTTPS (mTLS or JWT bearer) to the ingestion API, which shall validate, de■duplicate (based on last■seen timestamp), and update the associated asset record (if any) with the reported fields. | Should | FR■ASSET■002, FR■ASSET■003, FR■AGENT■001 |

| FR-AGENT-003 | The agent shall operate with a configurable sync interval (default 15 min) and cache data locally when offline, attempting to reseed on reconnect. It shall respect user privacy: no personal files, keystrokes, or screenshots are collected. | Should | FR■AGENT■001 |

| FR-ASSET-010 | The system shall provide an **AI■assisted data■cleanup** suggestion feature: given a batch of asset records, the model proposes normalized tag formats, corrected make/model values, and category mapping based on description patterns. Changes require explicit user approval before being applied. | Could | Incubator feature |

| FR-ASSET-011 | The system shall offer **predictive maintenance hints** based on historical maintenance logs (frequency, parts replaced, downtime) using a simple rule■based or ML model to flag assets that may benefit from pre■emptive service. | Could | Incubator feature |

| FR-ASSET-012 | The system shall include a **visual label designer** for Zebra■compatible templates: drag■and■drop fields (barcode, text, image), live preview, and ability to save/print directly to a configured printer or export as ZPL/EPL. | Should | Inferred from backlog (IB■11) |

| FR-ASSET-013 | The system shall allow bulk import of assets via CSV/JSON with a preview step that shows validation errors (duplicate tags, missing required fields, invalid references) and allows the user to accept/reject rows before committing. Import shall be idempotent (re■running the same file does not create duplicates). | Must | EV■ACCEPT■007 (PROPOSED: preview/validation, recoverable) |

| FR-ASSET-014 | The system shall allow export of asset lists (filtered by any search) to CSV, XLSX, or JSON, honoring current user's role■based field visibility (e.g., hide serial numbers from Read■Only roles). Export shall respect filters, sorting, and pagination. | Must | EV■ACCEPT■008 (PROPOSED: export respects filters/permissions) |

| FR-ASSET-015 | The system shall enforce file upload security: all attachments (images, documents) are scanned for malware on upload, stored in encrypted object storage with signed time-limited URLs, and never served directly without authentication. | Must | EV-ARCH-01 (PROPOSED: malware scanning, signed access); EV-SEC-MODEL-01 (PROPOSED) |

| FR-ASSET-016 | The system shall provide tenant-level data retention and deletion policies: administrators can define how long audit logs, asset history, and deleted records are retained before purge, and can initiate a GDPR-style deletion request that removes all personal data linked to a user. | Should | EV-ACCEPT-009-010 (PROPOSED: retention, deletion, export) |

| FR-NOTIF-001 | The system shall support configurable notification channels (email, SMS, in-app, webhook) for events such as: asset overdue, maintenance due, warranty expiring, audit discrepancy, and agent offline > 24 h. | Should | Inferred from backlog (IB-10) |

| FR-WEBHOOK-001 | Authorized administrators may configure outbound webhooks that fire on asset lifecycle events (check-in, check-out, maintenance completed, disposed) with a signed payload and retry policy (exponential backoff, max 5 attempts). | Should | Inferred from backlog (IB-16) |

| FR-API-001 | The system shall expose a versioned REST API (v1) with OpenAPI 3.0 specification, supporting CRUD operations on assets, sites, users, and audit sessions, requiring either session cookie or Bearer token (JWT/OAuth2) for authentication. | Should | EV-ARCH-01 (PROPOSED: versioned API/service layer) |

| FR-API-002 | All mutating API endpoints shall be idempotent where possible (using Idempotency-Key header) and shall return appropriate error codes (409 for duplicate tag, 403 for insufficient rights, 404 for not found). | Should | EV-ARCH-01 (PROPOSED: idempotency for retried commands) |

| FR-OBSERV-001 | The system shall emit structured logs (JSON) to a central location, and export metrics (Prometheus format) and traces (OpenTelemetry) for monitoring of latency, error rates, audit session length, and agent-ingest lag. | Should | EV-ARCH-01 (PROPOSED: centralized observability) |

| FR-BACKUP-001 | Automated, encrypted backups of the relational database and object storage metadata shall be taken daily, retained for 30 days, and tested for restore quarterly. | Should | EV-ARCH-01 (PROPOSED: automated backups) |

> **Note:** The above list is not exhaustive; each feature spec will elaborate further with scenarios, edge cases, and non-functional constraints.

8. Non-Functional Requirements

Format: `NFR--`

ID	Description	Priority	Linked Evidence / Reference
----	-------------	----------	-----------------------------

----	-----	-----	-----
------	-------	-------	-------

NFR-SEC-001	All service-to-service and service-to-client communication shall use TLS 1.2+; internal service calls shall be mutually authenticated where feasible (mTLS or JWT signed by internal auth service). Must Industry best practice; EV-SEC-MODEL-01 (PROPOSED)
-------------	---

NFR-SEC-002	Passwords shall be stored using Argon2id with a minimum memory cost of 64 MiB and time cost 3 iterations; the system shall enforce minimum length 12 and encourage passphrases.
-------------	---

Should | Common security standard |

| NFR-SEC-003 | Multi-factor authentication (TOTP, push, or hardware token) shall be available for all administrative roles and optionally enforceable for end-users. | Should | EV-SEC-MODEL-01 (PROPOSED: MFA-readiness) |

| NFR-SEC-004 | Single Sign-On (SAML 2.0, OIDC) shall be supported for tenant-level authentication, with just-in-time provisioning of users from the identity provider. | Should | EV-SEC-MODEL-01 (PROPOSED: SSO-readiness) |

| NFR-SEC-005 | All API responses shall include security headers: `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: SAMEORIGIN`, and `Referrer-Policy: strict-origin-when-cross-origin`. | Must | OWASP Secure Headers |

| NFR-SEC-006 | The system shall conduct automated role-based authorization tests nightly, attempting every combination of role/resource/action and asserting expectation; failures will block deployment until addressed. | Should | EV-SEC-MODEL-01 (PROPOSED: automated RBAC tests) |

| NFR-PERF-001 | 95 % of API requests (excluding bulk imports/exports) shall respond ≤ 250 ms under a sustained load of 100 RPS with 200 concurrent users (simulated). | Should | Industry SLA for internal tools |

| NFR-PERF-002 | Bulk import of up to 10 000 asset records shall complete within 2 minutes and not cause degradation of foreground requests (> 10 % latency increase). | Should | EV-ACCEPT-007 (PROPOSED: recoverable imports) |

| NFR-SCAL-001 | The system shall support horizontal scaling of stateless API workers and background workers; the relational database shall be able to handle ≥ 10 000 active assets per tenant with ≤ 5 ms 95th-percentile read latency. | Should | Cloud-native design |

| NFR-AVAIL-001 | The API shall target **99.9 % monthly uptime** (excluding scheduled maintenance windows communicated 24 h in advance). | Should | Typical SaaS SLA |

| NFR-MOB-001 | The responsive web application shall achieve a Lighthouse performance score ≥ 90 and accessibility score ≥ 85 on Chrome Lighthouse (simulated Moto G4) for the core audit flow. | Should | Common PWA targets |

| NFR-OFFL-001 | The progressive web app shall be usable offline for asset-scan audit sessions: cached assets, last known location, and the ability to store scanned results locally and sync on reconnection. | Should | Inferred from backlog (offline-capable audit) |

| NFR-encontrados-002 | The system shall support exporting audit logs in JSON and CSV format for external SIEM ingestion, preserving chain-of-custody and integrity hashes. | Should | EV-ACCEPT-012 (PROPOSED: observable audit) |

| NFR-LEGAL-001 | The system shall enable administrators to set data-residency preferences (e.g., store data only in specific cloud regions) where the underlying infrastructure allows it. | Should | Increasingly common regulatory requirement |

| NFR-LEGAL-002 | The system shall provide a data-processing-addendum (DPA) template for customers who require GDPR/CCPA compliance. | Should | Contractual need |

| NFR-MAINT-001 | The platform shall provide zero-downtime deployments using blue-green or canary strategies, with automated rollback on health-check failure. | Should | Modern DevOps |

| NFR-MAINT-002 | Schema migrations shall be backward-compatible (additive only) or provide a documented forward-/rollback path; no migration shall require downtime > 5 minutes. | Should | Industry practice |

9. Role-Aware Acceptance Criteria (Examples)

These criteria translate functional and non-functional requirements into testable scenarios for each major persona. Acceptance criteria will be refined during feature spec writing.

IT Asset Manager (IAM)

- **ACE-IAM-001**: Given IAM is logged in, when they navigate to the **Assets** list and filter by **Status = In Repair**, then they shall see only assets currently assigned that status, with columns for Asset Tag, Make/Model, Location, Expected Return Date, and the action **View Maintenance History**.
- **ACE-IAM-002**: Given IAM has the **Asset Admin** role, when they attempt to create a new asset with Asset Tag `LPT-0001` that already exists in the tenant (same normalized value), then the system shall reject the request with HTTP 409 and display the message **Asset Tag LPT-0001 already exists in this tenant**.
- **ACE-IAM-003**: Given IAM initiates an audit session for the **HQ-Floor-2** location, scans 50 assets, and finishes the session, then the system shall produce an annual report showing: total scanned, found, missing, mismatched, and a list of suggested reconciliation actions (based on last known location).
- **ACE-IAM-004**: Given IAM schedules a monthly PDF asset-by-department report to be emailed to the finance team, when the report runs, the recipients shall receive the PDF attachment and the system shall log the delivery with timestamp and recipient list.

Employee / End User (EU)

- **ACE-EU-001**: Given EU is logged in, when they open the **My Assets** page, then they shall see a list of assets currently assigned to them, with option to **Report Issue** or **Initiate Return**.
- **ACE-EU-002**: Given EU selects **Request New Laptop** from the catalog, fills the justification, and submits, then the request shall route to the IT Asset Manager's queue for approval and EU shall see a confirmation **Request submitted, awaiting approval**.
- **ACE-EU-003**: Given EU's assigned laptop has the endpoint agent installed and is currently offline for > 30 minutes, when the agent reconnects, the system shall update the asset's **Last Seen** timestamp and, if the agent reports a change in installed software, shall create an audit event **Software Change Detected**.

Field Technician (FT)

- **ACE-FT-001**: Given FT is logged in and has the **Field Tech** role, when they open a work order for asset `LPT-1234`, then they shall see the asset details, a barcode to scan for verification, and fields to log labor hours, parts used (with dropdown from inventory), and free-text notes.
- **ACE-FT-002**: Given FT scans an asset's barcode with the mobile PWA while offline, the application shall store the scan locally and show a badge **Offline – will sync when online**.

- **ACE-FT-003**: Given FT completes a maintenance work order and sets the asset condition to **Serviceable**, the system shall transition the asset status from **In Repair** to its prior state (e.g., **Assigned** if it was checked out) and create an audit event **Maintenance Completed**.

Finance & Procurement Lead (FPL)

- **ACE-FPL-001**: Given FPL runs the **Asset Cost Summary** report filtered by fiscal year Q3, then the report shall display total acquisition cost, total depreciation YTD, and average cost per asset grouped by department.
- **ACE-FPL-002**: Given FPL enables the **Warranty Expiry** alert policy with a 30-day lead time, when any asset's warranty date is within 30 days, then the assignee and the FPL shall receive an email notification.

Administrator / Superadmin (SA)

- **ACE-SA-001**: Given SA is logged in, when they navigate to **Tenants → Create Tenant**, enter a unique subdomain, and select a service plan, then the system shall provision the tenant, send a welcome email to the admin contact, and record the creation in the audit log.
- **ACE-SA-002**: Given SA sets the password policy to minimum length 14 and enables MFA for all admins, when a new admin user is invited and attempts to log in with a password shorter than 14 characters, the system shall reject the attempt and show the validation message.

> The above are examples; each feature spec will list a full set of ACE criteria.

10. Dependencies, Assumptions, Constraints, & Risks

Dependencies

- **Relational Database**: PostgreSQL 15+ (or compatible managed offering) for core asset data, audit logs, users, and permissions.
- **Object Storage**: S3-compatible service (e.g., MinIO, AWS S3, Azure Blob) for attachments, imports/exports, and backups.
- **Cache/Message Broker**: Redis 7+ for transient state, rate limiting, and background job coordination (optional, can use DB-based locks if preferred).
- **Background Job Processor**: Either a dedicated worker service (e.g., using Sidekiq, Hangfire, or custom Python workers) or the database-based job scheduler.
- **SMTP / SMS Gateway**: Third-party provider (e.g., SendGrid, Twilio, SES) for notifications; configurable via environment variables.
- **Antivirus Scanning Engine**: ClamAV 1.0+ (or equivalent) integrated into upload pipeline.

- **Identity Provider (optional):** Azure AD, Okta, Google Workspace for SSO; fallback to local DB auth.
- **Endpoint Agent Runtime:** .NET 6 runtime (Windows) or native binaries (macOS/Linux) – to be packaged and signed.

Assumptions

- Tenant count will initially be ≤ 100 ; each tenant will have $\leq 10\,000$ active assets.
- Network latency between client and API will average < 100 ms (typical broadband).
- The organization's security policy permits installing a signed endpoint agent on corporate-owned laptops.
- The organization provides a printer that accepts ZPL/EPL (Zebra-compatible) for label printing, or is willing to use a generic PDF label as fallback.
- The organization agrees to the data processing terms outlined in the DPA.

Constraints

- **Data sovereignty:** If the client requires EU-region data residency, the deployment must be provisioned in an Azure/AWS EU region.
- **Budget:** The SaaS operating cost (compute, storage, bandwidth) must stay within an agreed monthly ceiling (to be defined during commercial negotiation).
- **Supported Clients:** Supported browsers: Chrome ≥ 110 , Edge ≥ 110 , Safari ≥ 16 (macOS/iOS). Firefox support is a *could* item.
- **Language:** Interface language initially English (en-US); i18n framework ready for future translations.
- **Accessibility:** Must conform to WCAG 2.1 AA; verified with axe-core and manual testing.

Risks & Mitigations

Risk	Likelihood	Impact	Mitigation
------	------------	--------	------------

Endpoint agent deployment resistance (privacy concerns, IT overhead)	Medium	High (could block core differentiating feature)	• Provide opt-in/out per asset; • Open source agent code for review; • Clearly document data collected and its purpose; • Offer an agentless mode relying on periodic imports.
--	--------	---	---

Multi-tenant data leak due to misconfigured RLS or application bug	Low	Critical	• Implement automated tenant isolation test suite (nightly); • Use defense in depth: DB row-level security + application layer checks; • Conduct third-party penetration test before GA.
--	-----	----------	--

AI-assisted cleanup produces incorrect suggestions, leading to data corruption	Low	Medium	• Keep AI suggestions as <i>non-binding</i> proposals requiring explicit user approval; • Maintain inflexible immutable audit of all changes.
--	-----	--------	--

| Label design complexity increases scope and delays MVP | Medium | Medium | • Scope label designer to basic text/barcode fields initially; • Add advanced features (images, conditional logic) in v2. |

| Regulatory changes (e.g., new e-waste reporting laws) affect required fields | Low | Medium | • Design custom field system to be easily extensible; • Monitor regulatory updates quarterly. |

| Dependence on third party antivirus engine introduces vulnerability if engine outdated | Low | Low | • Allow configurable AV engine; • Provide update mechanism via admin console; • default to ClamAV with auto update schedule. |

| Vendor lock-in to a specific cloud provider complicates migration | Low | Medium | • Prefer managed services that are portable (e.g., PostgreSQL compatible, S3 compatible API); • Keep infrastructure as code (Terraform) and document migration steps. |

11. MVP Scope, Later Phases, & Exclusions

Minimum Viable Product (In Scope)

- Tenant provisioning & isolation.
- Identity & authentication (local DB, password based, MFA ready, SSO ready stub).
- Core RBAC: Super admin, Tenant Admin, IT Asset Manager, Field Technician, Employee, Auditor, Read Only; with basic permission grants (view asset, check out, check in, create maintenance, run audit, view reports).
- Asset registry with **tenant scoped unique Asset Tag**, serial number, make/model, category, site, location, department, custodian, status, purchase date, cost, warranty expiry, and attachment support (malware scanned, size/type limited).
- Lifecycle workflows: check out, check in, maintenance, reserve, disposal, retirement (basic state transitions).
- Audit session: barcode/QR scanning web UI, offline capable PWA variant (caches asset list, stores scans locally, syncs on reconnect), discrepancy flagging, and basic reconciliation (manual matching, no AI suggestions).
- Documents & attachments: upload (size ≤ 25 MB, types: pdf, jpg, png, docx, xlsx), malware scanning via ClamAV, stored encrypted, accessed via signed URL.
- Reports: 3 pre built reports (Asset List by Location, Asset by Custodian, Warranty Expiry + 30 days); CSV export with role based field visibility.
- Notifications: Email (via SMTP) for overdue check out (> 3 days), warranty expiring (≤ 30 days), and maintenance due.
- Administration: tenant logo upload, email sender configuration, and webhook subscription for asset lifecycle events.
- Observability: structured logs (JSON), Prometheus metrics endpoint, basic health checks.
- Backup: daily encrypted dump of DB + object storage metadata, retained 7 days, restore test procedure documented.

- Deployment: Docker■compose based dev/staging; production using managed PaaS (e.g., Azure App Service + Azure SQL + Azure Blob) or equivalent, with IaC (Terraform) scripts provided.

Later■Phase (Post■MVP, Subject to Approval)

- AI■assisted asset■tag cleanup and data normalization.
- Predictive maintenance hints based on historical work■order data.
- Visual label designer (full drag■and■drop, image support, print■job submission to Windows/macOS CUPS/LPR).
- Advanced report builder with charts, grouping, and scheduled email/FTP delivery.
- Deep integrations: webhook signature verification, inbound API for bulk asset imports from HRIS/CMDB, SCIM user provisioning.
- Enhanced custodial workflows: multi■step approvals, temporary loans, and automated asset■recovery workflows (if asset reported stolen).
- Sustainability metrics: power usage estimation (if hardware provides), e■waste tracking, and asset■lifespan reporting.
- Geofencing / GPS■based location tagging for high■value mobile assets (optional hardware add■on).
- Plugin■marketplace for community■contributed widgets and report templates.

Explicit Non■Goals (Out of Scope for MVP)

- Real■time GPS tracking of assets (requires dedicated hardware).
- Full■featured CMDB with CI/CD pipeline tracking and software■license entitlement reconciliation.
- In■depth financial depreciation engines (straight■line, declining balance, etc.) – can be added via custom fields and reports.
- Native mobile apps (iOS/Android) – rely on progressive web app; native considered only if PWA fails to meet performance.
- On■premises installation – SaaS■only offering; private■cloud offering possible later under separate licensing.
- Built■in electronic signature capture – can be attached as a document.
- Support for legacy barcode symbologies beyond Code■128, QR■Code, and Data■Matrix (can be added via scanner configuration).

12. Evidence Classification & Links to Traceability Matrix

Every requirement, design decision, and acceptance criteria above shall be mapped in the traceability matrix (‘docs/delivery/TRACEABILITY-MATRIX.md’) to one or more evidence items from the supplied V7.1 pack. The matrix will contain columns:

- **Requirement ID** (e.g., FR-ASSET-001)
- **Requirement Statement**
- **Source Evidence File & ID** (e.g., `business-rules/BUSINESS-RULES-CATALOG.json` - BR-0017)
- **Classification** (OBSERVED/INFERRED/PROPOSED/UNKNOWN/CONFLICTING)
- **Proposed Design Decision or ADR**
- **Acceptance Criterion / Test Scenario** (e.g., ACE-IAM-002)
- **Implementation Epic / Issue Placeholder** (to be created in project management tool)
- **Status** (Pending, In Progress, Done)
- **Owner**

Evidence items referenced in this PRD include (non-exhaustive list):

- `00-START-HERE.md` – overall synthesis totals (OBSERVED/INFERRED)
- `02-COVERAGE-AND-GAPS.md` – unknowns list (UNKNOWN)
- `ai-context/AI-AGENT-MASTER-CONTEXT.md` – precedence, mandatory principles (PROPOSED)
- `ai-context/IMPLEMENTATION-BACKLOG.md` – backlog items (PROPOSED)
- `ai-context/REBUILD-ACCEPTANCE-CRITERIA.md` – acceptance criteria (PROPOSED)
- `architecture/TECHNICAL-ARCHITECTURE.md` – observed and recommended architecture (OBSERVED/PROPOSED)
- `architecture/TECHNOLOGY-AND-SAAS-EVIDENCE.json` – observed technologies (OBSERVED)
- `business-rules/BUSINESS-RULES-CATALOG.json` – business rules (OBSERVED)
- `business-rules/BUSINESS-RULES-CATALOG.md` – human-readable rules (OBSERVED)
- `contracts/ENDPOINT-CATALOG.csv` – endpoints (OBSERVED)
- `contracts/ENDPOINT-CATALOG.json` – endpoint details (OBSERVED)
- `data-model/ER-DIAGRAM.mmd` – entity relationship diagram (INFERRED)
- `data-model/LOGICAL-DATA-MODEL.json` – logical data model (INFERRED)
- `manifests/V7-MANIFEST.json` – synthesis manifest (OBSERVED)
- `product/FEATURE-MODULES.md` – feature modules (OBSERVED/INFERRED)
- `product/SCREEN-ROUTE-CATALOG.json` – route and screen catalog (OBSERVED/INFERRED)
- `security/SECURITY-AUTHORIZATION-EVIDENCE.json` – cookies, antiforgery, logged-out behavior (OBSERVED)
- `security/SECURITY-AUTHORIZATION-MODEL.md` – authorization model notes (OBSERVED/PROPOSED)

> The traceability matrix will be completed during the specification phase and will be maintained as a living document linking PRD → specs → tests → releases.

13. Open Decisions Requiring Client Approval

The following items are ****PROPOSED**** in this PRD and require explicit client approval before they become binding requirements:

1. ****Endpoint Agent Deployment Model**** – Should the agent be mandatory for all laptops, optional per asset, or offered as a separate paid add-on? What are the data privacy guarantees and opt-out mechanisms?
2. ****Asset Tag Uniqueness Policy**** – Shall we treat the tag as case insensitive, enforce a specific prefix convention (e.g., `LOC-ASSET-####`), and define how to handle existing duplicates during migration?
3. ****Label Printing Hardware**** – Shall we assume the customer owns a Zebra compatible printer, or shall we provide a fallback to generate PDF labels for any printer?
4. ****Data Retention Periods**** – What are the default retention times for audit logs (e.g., 2 years), asset history (e.g., 7 years after disposal), and deleted personal data (e.g., 30 days after deletion request)?
5. ****Notification Channels**** – Which notification providers (email, SMS, Slack, Teams, webhook) shall be included in MVP, and which are deferred to later phases?
6. ****Subscription & Billing Model**** – Shall we charge per active asset per month, per user, or a tiered plan based on number of assets and features enabled? Will we offer a free trial?
7. ****Degree of UI Customization**** – Shall we allow tenants to upload a logo and choose primary/secondary brand colors, or support full theming via CSS variables?
8. ****Integration First Party vs. Marketplace**** – Shall we build a few core integrations (ServiceNow, JIRA, Azure AD) in-house, or provide a webhook based extension framework for partners to build connectors?
9. ****AI Feature Consent Model**** – How will we obtain consent for AI based data cleanup suggestions (per asset, per tenant, opt-in/out) and ensure explainability?
10. ****Disaster Recovery RPO/RTO**** – What are the agreed recovery point objective (maximum data loss in minutes) and recovery time objective (maximum downtime) for production incidents?

Each of these will be captured as a ****decision record**** in `docs/decisions/` with impact analysis, alternatives, and a resolution date once approved.

--- End of PRD (Version 1.0.0) ---